

AI-FDE Brownfield Repo Transformation Challenge Guide

Purpose

This guide is separate from the repositories. The repos should be treated as realistic brownfield systems. Participants should discover issues from code, data, configuration, tests, logs and documentation rather than from trainer notes embedded inside the repo.

The expected transformation journey is:

Understand Existing Repo -> Establish Behavioural Baseline -> Identity & Least Privilege -> Secrets & Encryption -> Infrastructure as Code -> Policy as Code -> CI/CD & Supply Chain -> Observability & Traceability -> AI Security & Guardrails -> Performance & Scalability -> Reliability & Failure Engineering -> Cost & AI FinOps -> Automated Security Validation -> Auditability & Compliance Evidence -> Production Readiness Gate -> Production Evidence Pack

Participant Expectation

Participants are expected to act like a real AI-FDE / AI-native SDLC transformation team taking ownership of a business-critical brownfield system.

They must not merely make the application run. They must understand the current estate, preserve critical behaviour, reduce risk, improve controls, make AI governable, prove operational readiness and produce evidence that can withstand engineering, security, SRE, compliance and business review.

Core Transformation Challenges

1. Understand Existing Repo

Challenge: Create the repo discovery dossier.

Execution Focus: Map current architecture, business flows, components, data stores, integrations, legacy modules, AI touchpoints, ownership boundaries and risk hotspots.

Expected Deliverables: Current-state architecture map, component inventory, business flow reconstruction, data and integration map, AI subsystem discovery and brownfield risk register.

Acceptance Standard: Evidence must come from code, data, configuration, tests or repository documentation.

2. Establish Behavioural Baseline

Challenge: Capture current behaviour before changing it.

Execution Focus: Run available checks, execute smoke tests, profile synthetic data, document current API/ETL behaviour and add characterization tests for risky legacy behaviour.

Expected Deliverables: Baseline test report, behaviour snapshot, characterization tests, data quality baseline and current defect list.

Acceptance Standard: The team can distinguish intended legacy behaviour from defects that must be fixed.

3. Identity & Least Privilege

Challenge: Design the least-privilege access model.

Execution Focus: Inspect human roles, service accounts, AI identities, vendor accounts, broad role checks and missing context constraints. Propose contextual RBAC plus ABAC.

Expected Deliverables: Current role matrix, target access matrix, policy input model, negative access tests and privilege reduction backlog.

Acceptance Standard: Access decisions must consider role, resource, purpose, scope and risk context.

4. Secrets & Encryption

Challenge: Remove unsafe secrets and harden sensitive data handling.

Execution Focus: Find hardcoded credentials, unsafe environment examples, sensitive data in logs, weak token practices and missing encryption assumptions.

Expected Deliverables: Secrets inventory, remediation plan, cleaned configuration model, sensitive-field handling checklist and rotation evidence plan.

Acceptance Standard: No sensitive value should be required in committed code or unsafe example configuration.

5. Infrastructure as Code

Challenge: Make environment assumptions reproducible.

Execution Focus: Inspect incomplete IaC, hidden setup steps, environment drift, local bootstrapping gaps and manually assumed dependencies.

Expected Deliverables: IaC gap report, reproducible setup guide, environment model, configuration ownership map and deployment dependency list.

Acceptance Standard: A new team can reproduce the intended local environment with documented steps.

6. Policy as Code

Challenge: Convert governance expectations into executable checks.

Execution Focus: Select high-risk decisions and encode policies for access, AI approval, data use, operational safety and production readiness.

Expected Deliverables: Policy catalogue, policy-as-code rules, allow/deny examples, policy tests and exception-handling model.

Acceptance Standard: At least one high-risk business decision must be governed by executable policy with positive and negative cases.

7. CI/CD & Supply Chain

Challenge: Strengthen the delivery and dependency path.

Execution Focus: Assess CI gaps, dependency risks, missing SBOM, manual release controls, insufficient test stages and absence of evidence capture.

Expected Deliverables: Pipeline improvement plan, dependency risk register, SBOM recommendation, security scan plan and release evidence checklist.

Acceptance Standard: The proposed pipeline must generate evidence, not only execute commands.

8. Observability & Traceability

Challenge: Build an explainable production trail.

Execution Focus: Design correlation across UI, API, legacy jobs, ETL, AI invocation, policy decision, human approval and audit event.

Expected Deliverables: Trace design, log schema, metric catalogue, dashboard sketch, SLO proposal and incident reconstruction example.

Acceptance Standard: The team must be able to explain one business event end to end.

9. AI Security & Guardrails

Challenge: Secure the AI trust boundary.

Execution Focus: Locate where AI output influences decisions. Add prompt-injection tests, retrieval trust checks, output schema validation, model/version provenance and human approval gates.

Expected Deliverables: AI risk register, trust-boundary diagram, guardrail test pack, model provenance design, approval workflow and unsafe-output handling rules.

Acceptance Standard: AI recommendations must not silently become operational decisions.

10. Performance & Scalability

Challenge: Find bottlenecks under realistic operating load.

Execution Focus: Profile API, ETL, event volume, data access, synchronous chains, AI latency and expensive retries using the included synthetic datasets.

Expected Deliverables: Performance baseline, bottleneck list, load scenarios, scaling recommendations and data access findings.

Acceptance Standard: Findings must tie technical bottlenecks to business impact.

11. Reliability & Failure Engineering

Challenge: Design for failure, replay and degraded mode.

Execution Focus: Inject failures such as duplicate events, stale data, AI timeout, partner/API failure, telemetry gaps and partial batch failure.

Expected Deliverables: Failure-mode catalogue, idempotency plan, retry/circuit-breaker strategy, degraded-mode design and recovery evidence.

Acceptance Standard: The system must define what continues safely when dependencies fail.

12. Cost & AI FinOps

Challenge: Connect technical usage to business cost.

Execution Focus: Track token count, AI retries, fallback behaviour, event processing cost, observability volume and cost per business outcome.

Expected Deliverables: AI cost baseline, cost per workflow, retry cost analysis, optimization backlog and FinOps dashboard fields.

Acceptance Standard: Cost must be explained per business outcome, not only as total spend.

13. Automated Security Validation

Challenge: Prove security controls repeatedly.

Execution Focus: Create tests for unauthorized access, policy bypass, prompt injection, sensitive-data leakage, insecure defaults and unsafe AI actions.

Expected Deliverables: Security test suite plan, negative tests, scanning checklist, abuse-case evidence and remediation backlog.

Acceptance Standard: Security claims must be backed by repeatable validation.

14. Auditability & Compliance Evidence

Challenge: Reconstruct decisions end to end.

Execution Focus: Pick one business event and reconstruct actor, request, data used, model/version, policy result, approval, final action and missing evidence.

Expected Deliverables: Audit gap report, decision provenance model, evidence chain, compliance evidence mapping and before/after audit example.

Acceptance Standard: The evidence chain must show what happened, who/what influenced it, and what cannot yet be proven.

15. Production Readiness Gate

Challenge: Make a defensible go/no-go decision.

Execution Focus: Evaluate readiness based on tests, controls, evidence, open risks, ownership and operational maturity.

Expected Deliverables: Readiness checklist, residual risk register, go/no-go decision, risk owner table and deferred work list.

Acceptance Standard: The team must state what is ready, what is not ready and what risk is accepted.

16. Production Evidence Pack

Challenge: Package the proof, not just the code.

Execution Focus: Assemble transformation evidence from tests, policies, logs, traces, AI evaluations, security checks, runbooks and readiness decisions.

Expected Deliverables: Final evidence pack, executive summary, test/security/AI/observability/reliability/FinOps evidence and production readiness decision.

Acceptance Standard: A reviewer can verify the transformation without relying on verbal explanation.

Moonshot Stretch Challenges

Moonshot 1: Decision Provenance Engine

Record every important decision as structured evidence: actor, request, data, policy, model, recommendation, approval, action, risk and trace ID.

Moonshot 2: AI Governance Gateway

Centralize prompt validation, retrieval filtering, output schema validation, model tracking, sensitive-data minimization, human approval and cost capture.

Moonshot 3: Self-Generating Evidence Pack

Automatically assemble test results, policy decisions, traces, audit logs, security scans, AI evaluation results and readiness checks into a release evidence pack.

Moonshot 4: Digital Twin / Simulation Mode

Add a simulation path for high-risk workflow changes such as outage response, route optimization, network remediation or clinical operations.

Moonshot 5: Risk-Based Autonomous Workflow

Allow limited AI-assisted action only when low-risk, reversible, policy-approved, observable, human-overridable and fully audited.

Moonshot 6: Executive Readiness Dashboard

Show transformation maturity, open risks, AI risk posture, evidence completeness, cost trends, resilience and compliance readiness.

Moonshot 7: Domain-Specific Control Tower

Create a role-aware operational control tower that joins live events, business state, AI decisions, policy outcomes and incident evidence.

Moonshot 8: Continuous Red-Team Harness

Build a repeatable attack and failure harness covering prompt injection, stale data, event replay, authorization bypass and unsafe recommendations.

Develop & Extract Semantic Layer

Develop PRD

Develop APP

Demo

Test Semantic Layer with new model

Compare and contrast APPs - Both Models

Final Submission Standard

A strong team submits a defensible transformation evidence pack, not just modified code. The final claim should be:

We understand this system, we know its risks, we improved it safely, we can prove what changed, and we can defend whether it is production-ready.